iscte

Mestrado em ⟨Nome do Mestrado⟩

Segurança em Redes e Sistemas de Informação

Autores:

Nome 1, N.º xxxxx
Nome 2, N.º yyyyy

Data: 17-10-26

Título do trabalho:

Segurança em Camadas para Comunicações IoT Baseadas em MQTT: Revisão Sistemática da Literatura e Proposta de Arquitetura

Docente: ⟨Nome do Docente⟩

Repositório: `https://github.com/joaoaeafonso/mqtt_secure`

Resumo

O protocolo MQTT tornou-se o padrão *de facto* para a troca de mensagens na Internet das Coisas, mas a sua especificação deixa a segurança quase inteiramente ao critério de quem o implementa. Como todas as mensagens atravessam um *broker*, a proteção do canal com TLS não basta: termina no próprio *broker*, que passa a ver, guardar e reencaminhar todo o conteúdo, e não impede a repetição de mensagens, a injeção por clientes legítimos nem o abuso de uma chave comprometida. Este trabalho apresenta uma revisão sistemática da literatura sobre mecanismos de segurança para comunicações baseadas em MQTT, conduzida segundo um protocolo explícito: perguntas de investigação, critérios PICOC, *strings* de pesquisa com grupos de sinónimos, critérios de inclusão, exclusão e qualidade, leitura em três passagens e formulário de extração de dados. Analisam-se 26 estudos primários publicados entre 2014 e 2026 e cinco revisões relacionadas, classificados numa taxonomia de oito categorias e comparados segundo as propriedades de segurança que garantem. A comparação mostra que a literatura trata sobretudo autenticação, controlo de acesso e confidencialidade, mas raramente reporta, em conjunto, a ligação criptográfica da mensagem ao tópico, a proteção contra repetição, a política do recetor contra a redução do nível de proteção e a restrição dos tópicos em que cada chave pode publicar. Com base nestas lacunas, propõe-se uma arquitetura de segurança em camadas, composta por camadas independentes e comutáveis entre a aplicação e o transporte, que combina defesa no transporte, um envelope fim-a-fim com AES-256-GCM ou Ed25519 e limitação de tráfego antes de qualquer operação criptográfica. A avaliação experimental da proposta é remetida para a segunda parte do projeto.

Palavras-chave: MQTT; Internet das Coisas; segurança fim-a-fim; cifra autenticada; revisão sistemática da literatura; defesa em profundidade.

Contents

List of Figures

List of Tables

Glossário

Sigla	Significado
AAD	*Additional Authenticated Data* — dados autenticados mas não cifrados
ABE	*Attribute-Based Encryption* — cifra baseada em atributos
ACL	*Access Control List* — lista de controlo de acessos
AEAD	*Authenticated Encryption with Associated Data* — cifra autenticada com dados associados
AES	*Advanced Encryption Standard*
AugPAKE	*Augmented Password-Authenticated Key Exchange*
CA	*Certificate Authority* — autoridade de certificação
CP-ABE / KP-ABE	ABE com política no criptograma / na chave
CRL	*Certificate Revocation List* — lista de certificados revogados
DoS / DDoS	*(Distributed) Denial of Service* — negação de serviço (distribuída)
ECC	*Elliptic Curve Cryptography* — criptografia de curvas elípticas
Ed25519	Esquema de assinatura EdDSA sobre a curva Edwards25519
GCM / GMAC	*Galois/Counter Mode* / *Galois Message Authentication Code*
HMAC	*Keyed-Hash Message Authentication Code*
IDS	*Intrusion Detection System* — sistema de deteção de intrusões
IoT	*Internet of Things* — Internet das Coisas
MAC	*Message Authentication Code* — código de autenticação de mensagem
MitM	*Man-in-the-Middle* — ataque de intermediário
ML	*Machine Learning* — aprendizagem automática
MQTT	*Message Queuing Telemetry Transport*
MQTT-SN	MQTT para redes de sensores (*Sensor Networks*)
mTLS	TLS mútuo (autenticação do cliente por certificado)
OAuth	*Open Authorization*
PICOC	*Population, Intervention, Comparison, Outcome, Context*
PRISMA	*Preferred Reporting Items for Systematic Reviews and Meta-Analyses*
QoS	*Quality of Service* — nível de garantia de entrega no MQTT
QE / QF / QG	Questão estatística / focada / geral (perguntas de investigação)
RFC	*Request for Comments* (documento normativo do IETF)
RSL	Revisão Sistemática da Literatura
SRSI	Segurança em Redes e Sistemas de Informação
STRIDE	*Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege*
TEE	*Trusted Execution Environment* — ambiente de execução confiável
TLS	*Transport Layer Security*

1 Introdução

1.1 Contexto

A Internet das Coisas (IoT) liga sensores, atuadores e serviços de *back-end* que trocam pequenas mensagens, com frequência e, muitas vezes, a partir de dispositivos com recursos muito limitados. Entre os protocolos da camada de aplicação usados neste domínio [**?**], o *Message Queuing Telemetry Transport* (MQTT) impôs-se pela sua simplicidade: normalizado pela OASIS nas versões 3.1.1 [**?**] e 5.0 [**?**], segue o paradigma publicação/subscrição, no qual os clientes nunca comunicam diretamente uns com os outros. Um *publisher* envia mensagens para um *tópico* (por exemplo, `fabrica/sala1/temperatura`), e um intermediário, o *broker*, entrega-as a todos os clientes cuja subscrição corresponda a esse tópico. Implementações abertas como o Eclipse Mosquitto [**?**] tornaram o protocolo omnipresente, de casas inteligentes a ambientes industriais e médicos.

1.2 Problema

A especificação do MQTT trata a segurança como responsabilidade da implementação: oferece um campo de nome de utilizador e palavra-passe no pedido de ligação e recomenda o uso de TLS, mas não define proteção da mensagem em si. Daqui resultam três problemas que estruturam este trabalho.

P1. O *broker* é um ponto de confiança total. O TLS protege apenas cada salto cliente–*broker* [**?**]. No *broker*, as mensagens existem em claro: quem o comprometer, ou qualquer cliente a quem uma lista de controlo de acessos mal configurada permita subscrever o filtro `#`, vê e pode reencaminhar todo o tráfego [**?**, **?**, **?**].

P2. Autenticidade não é frescura. Mesmo uma mensagem criptograficamente autêntica pode ser capturada e repetida mais tarde, ou publicada num tópico diferente daquele para que foi criada. Sem números de sequência, carimbos temporais e ligação ao tópico, a autenticação não impede estes ataques.

P3. Comprometimento de dispositivos. Num parque com milhares de dispositivos, alguns acabarão comprometidos. Se uma chave válida puder publicar em qualquer tópico, um único dispositivo comprometido pode fazer-se passar por todos os outros, e o incidente de botnets como a Mirai [**?**] mostra a escala que estes ataques podem atingir.

A literatura propõe numerosas soluções parciais, desde esquemas de autenticação e autorização a cifras baseadas em atributos e ambientes de execução confiáveis, mas é difícil perceber que propriedades cada uma garante, que ameaças deixa por tratar e como se combinam. É este o problema que a revisão endereça: *que mecanismos de segurança propõe o estado da arte para comunicações baseadas em MQTT, que propriedades garantem e que lacunas persistem?*

1.3 Objetivos

O1. Conduzir uma revisão sistemática da literatura, segundo um protocolo explícito e reprodutível [**?**, **?**], sobre mecanismos de segurança para o MQTT.

O2. Classificar as soluções encontradas numa taxonomia e compará-las segundo um conjunto comum de propriedades de segurança e de avaliação.

O3. Comparar a presente revisão com as revisões já publicadas sobre o tema.

O4. Identificar as lacunas do estado da arte e, a partir delas, propor uma arquitetura de segurança em camadas, descrita formalmente, cuja avaliação experimental é objeto da segunda parte do projeto.

1.4 Contributos

- Um protocolo de revisão completo (perguntas, PICOC, *strings* por base de dados, critérios de inclusão, exclusão e qualidade, formulário de extração), reutilizável e reprodutível (Secção **??**).
- Uma comparação de 26 estudos primários e de 5 revisões relacionadas, com uma matriz de propriedades de segurança (Secções **??** e **??**).
- A formalização de mecanismos que a literatura raramente combina: ligação da mensagem ao tópico, janela anti-repetição, política do recetor contra a redução do nível de proteção e restrição chave–tópico (Secção **??**).
- Uma arquitetura modular cuja implementação de referência é disponibilizada num repositório público [**?**], com documentação técnica completa.

1.5 Estrutura do documento

A Secção **??** apresenta os fundamentos: o protocolo MQTT, os seus mecanismos nativos de segurança, as primitivas criptográficas relevantes e o modelo de ameaças. A Secção **??** descreve o protocolo da revisão sistemática. A Secção **??** analisa as revisões já publicadas e justifica a presente. A Secção **??** apresenta os resultados: a caracterização estatística dos estudos, a taxonomia, a comparação detalhada e as respostas às perguntas de investigação. A Secção **??** propõe a arquitetura em camadas e posiciona-a face aos trabalhos relacionados. A Secção **??** discute as lacunas e as ameaças à validade, e a Secção **??** conclui e aponta o trabalho futuro. Os anexos contêm as *strings* de pesquisa adaptadas a cada base de dados e a extração de dados por estudo.

2 Enquadramento teórico

Esta secção reúne os conceitos necessários para ler a revisão e a proposta: o funcionamento do MQTT, os mecanismos de segurança que o protocolo e os seus *brokers* oferecem nativamente, as primitivas criptográficas usadas pelas soluções analisadas e o modelo de ameaças que serve de referência à comparação.

2.1 O protocolo MQTT

O MQTT é um protocolo cliente–servidor de publicação/subscrição que funciona sobre um transporte ordenado e fiável, normalmente TCP (porta 1883) ou TLS (porta 8883) [**?**]. A

Figura **??** ilustra os papéis envolvidos. Os clientes não se conhecem entre si: o desacoplamento no espaço, no tempo e na sincronização é precisamente o que torna o protocolo escalável, mas também o que concentra a confiança no *broker*.

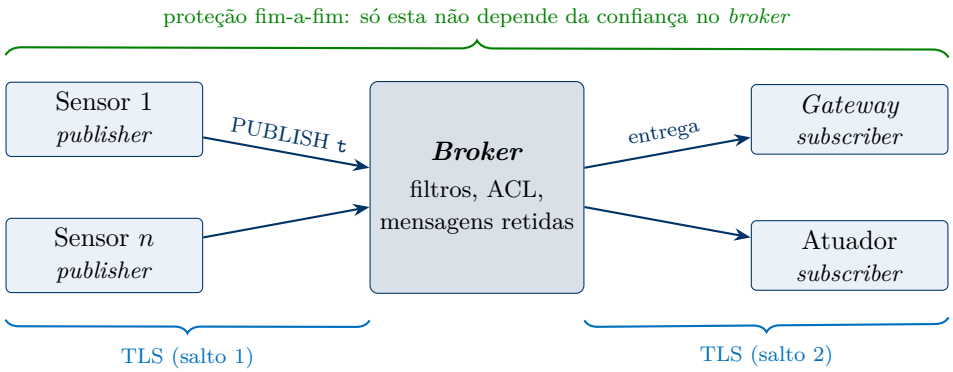


Figure 1. Arquitetura de publicação/subscrição do MQTT. O TLS protege cada salto em separado e termina no *broker*; só a proteção fim-a-fim da mensagem sobrevive a um *broker* não confiável.

Pacotes. O protocolo define catorze tipos de pacote na versão 3.1.1 (CONNECT, CONNACK, PUBLISH, PUBACK, PUBREC, PUBREL, PUBCOMP, SUBSCRIBE, SUBACK, UNSUBSCRIBE, UNSUBACK, PINGREQ, PINGRESP e DISCONNECT), a que a versão 5.0 acrescenta AUTH [**?**]. Cada pacote tem um cabeçalho fixo de dois a cinco octetos, o que explica a eficiência do protocolo em ligações limitadas.

Tópicos e filtros. Os tópicos são cadeias UTF-8 hierárquicas separadas por `/`. As subscrições usam *filtros* com dois carateres especiais: `+` corresponde a exatamente um nível e `#` a qualquer número de níveis, apenas no fim do filtro. Tópicos começados por `$` (como `$SYS/...`, com estatísticas do *broker*) não são abrangidos por filtros que comecem por um destes carateres. Formalmente, sendo um tópico $\tau = (\tau_1, \ldots, \tau_m)$ e um filtro $f = (f_1, \ldots, f_k)$ sequências de níveis, define-se a correspondência por

$$\mathrm{corr}(f, \tau) \iff \begin{cases} \exists j \le \min(k, m+1) : \; f_j = \texttt{\#} \;\wedge\; \forall i < j : \; f_i \in \{\tau_i, \texttt{+}\}, \\ k = m \;\wedge\; \forall i \le k : \; f_i \in \{\tau_i, \texttt{+}\}, \end{cases} \tag{1}$$

com a restrição adicional de que, se τ_1 começa por `$`, então $f_1 \notin \{\texttt{+}, \texttt{\#}\}$. Esta relação é usada pelas listas de controlo de acessos e, na proposta, pela restrição chave–tópico (Secção **??**).

Qualidade de serviço. O MQTT oferece três níveis de entrega: QoS 0 (no máximo uma vez), QoS 1 (pelo menos uma vez, com possíveis duplicados marcados pela *flag* DUP) e QoS 2 (exatamente uma vez, com um protocolo de quatro passos). Note-se que os duplicados legítimos do QoS 1 são indistinguíveis, para um mecanismo anti-repetição, de uma repetição maliciosa — uma tensão que a proposta tem de resolver.

Mensagens retidas e sessões. O *broker* pode reter a última mensagem de cada tópico e entregá-la a novos subscritores, e pode manter sessões persistentes entre ligações. Ambos os

mecanismos implicam que o *broker* armazena conteúdo, o que agrava o problema P1.

2.2 Segurança nativa do MQTT e dos *brokers*

A Tabela **??** resume o que o protocolo e os *brokers* comuns oferecem sem extensões.

Table 1. Mecanismos de segurança nativos do MQTT e dos *brokers* e respetivas limitações.

Mecanismo	O que oferece	Limitação
Utilizador e palavra-passe (CONNECT)	Autenticação do cliente pelo *broker*	Em claro sem TLS; não autentica mensagens individuais nem o *broker*
TLS 1.2/1.3 [**?**, **?**]	Confidencialidade e integridade de cada salto; autenticação do servidor	Termina no *broker*; custo de estabelecimento em dispositivos restritos [**?**]; um cliente só controla o seu próprio salto [**?**]
TLS mútuo (certificado de cliente)	Autenticação forte do cliente; identidade = nome comum do certificado	Exige infraestrutura de chave pública e revogação (CRL)
Listas de controlo de acessos	Autorização por tópico (leitura/escrita) no *broker*	Baseiam-se na identidade declarada se não houver autenticação; não protegem contra o próprio *broker*
Autenticação estendida (AUTH, MQTT 5)	Métodos de desafio–resposta definidos pela aplicação	Só autenticação da ligação; não protege o conteúdo

Nenhum destes mecanismos protege a *mensagem* de ponta a ponta. É neste espaço que se situa a maior parte das propostas da literatura e a arquitetura proposta neste trabalho.

2.3 Primitivas criptográficas

2.3.1 Cifra autenticada com dados associados

Uma cifra AEAD é um par de algoritmos que garante, numa só operação, confidencialidade do texto em claro e integridade e autenticidade tanto do texto como de dados associados que seguem em claro:

$$(C, T) = \mathrm{AEAD.Enc}(K, N, P, A), \tag{2}$$

$$\mathrm{AEAD.Dec}(K, N, C, T, A) = \begin{cases} P & \text{se } T \text{ é válido para } (N, C, A), \\ \bot & \text{caso contrário,} \end{cases} \tag{3}$$

onde K é a chave, N o *nonce*, P o texto em claro, A os dados associados (AAD), C o criptograma e T a etiqueta de autenticação. O facto de A ser autenticado sem ser cifrado é o que permite ligar criptograficamente a uma mensagem metadados que têm de permanecer legíveis, como o cabeçalho ou o tópico MQTT.

AES-GCM. No modo GCM [**?**], com chave K e *nonce* de 96 bits, calcula-se a subchave $H = E_K(0^{128})$ e o bloco inicial $J_0 = N \,\|\, 0^{31} \,\|\, 1$. O texto é cifrado em modo contador a partir de

$J_0 + 1$ e a etiqueta é

$$T = \mathrm{MSB}_t(\mathrm{GHASH}_H(A \,\|\, 0^v \,\|\, C \,\|\, 0^u \,\|\, [\mathrm{len}(A)]_{64} \,\|\, [\mathrm{len}(C)]_{64}) \oplus E_K(J_0)) \,, \tag{4}$$

onde GHASH_H é uma função polinomial em $\mathrm{GF}(2^{128})$ e u, v completam blocos de 128 bits. Com P vazio obtém-se o GMAC, um código de autenticação de mensagem: $T = \mathrm{AEAD.Enc}(K, N, \varnothing, A)$.

Limite dos *nonces* aleatórios. A segurança do GCM colapsa se o mesmo par (K, N) for usado duas vezes: o XOR dos dois criptogramas revela o XOR dos textos e a subchave H pode ser recuperada, permitindo falsificar etiquetas [**?**]. Com *nonces* aleatórios de $b = 96$ bits e q mensagens por chave, a probabilidade de colisão é limitada pelo paradoxo do aniversário:

$$\Pr[\text{colisão}] \;\le\; \frac{q(q-1)}{2^{b+1}} \;\approx\; \frac{q^2}{2^{97}}. \tag{5}$$

Para $q = 2^{32}$ a probabilidade é da ordem de 2^{-33}, razão pela qual o NIST limita a 2^{32} o número de invocações por chave com *nonces* aleatórios [**?**]. Esquemas de longa duração precisam, por isso, de rotação de chaves.

ChaCha20-Poly1305. Alternativa sem dependência de instruções AES em *hardware*, com chave de 256 bits, *nonce* de 96 bits e etiqueta de 128 bits [**?**]; é a escolha de [**?**] para nós restritos.

2.3.2 Códigos de autenticação de mensagem

O HMAC [**?**] constrói um MAC a partir de uma função de *hash* $\mathcal{H}$:

$$\mathrm{HMAC}(K, m) = \mathcal{H}\big((K' \oplus \mathit{opad}) \,\|\, \mathcal{H}((K' \oplus \mathit{ipad}) \,\|\, m)\big), \tag{6}$$

onde K' é a chave ajustada ao tamanho do bloco. Um MAC dá integridade e autenticidade face a quem não conhece K, mas *não* prova a origem perante terceiros: qualquer detentor de K (incluindo o recetor) pode produzir a mesma etiqueta.

2.3.3 Assinaturas digitais Ed25519

O Ed25519 [**?**, **?**] é um esquema de assinatura sobre a curva de Edwards equivalente à Curve25519, com ponto base B de ordem prima ℓ. A partir da chave privada (32 octetos) derivam-se o escalar s e a chave pública $A = [s]B$. Para assinar M:

$$r = \mathcal{H}(\mathit{prefixo} \,\|\, M) \bmod \ell, \quad R = [r]B, \quad k = \mathcal{H}(R \,\|\, A \,\|\, M) \bmod \ell, \quad S = (r + k\,s) \bmod \ell, \tag{7}$$

e a assinatura é (R, S), com 64 octetos. A verificação aceita sse

$$[8][S]B = [8]R + [8][k]A. \tag{8}$$

Como r é derivado deterministicamente da chave e da mensagem, o esquema elimina a dependência de um gerador aleatório no momento da assinatura. Ao contrário de um MAC, só o detentor de

s consegue assinar, enquanto qualquer detentor de A consegue verificar: a assinatura dá *prova de origem* (não repúdio).

2.4 Frescura e proteção contra repetição

Janela temporal. Dada uma mensagem com carimbo temporal t_m, recebida no instante t, um recetor com tolerância de idade Δ_a e de desvio de relógio Δ_s aceita-a sse

$$t - \Delta_a \;\le\; t_m \;\le\; t + \Delta_s. \tag{9}$$

A frescura limita o tempo durante o qual uma mensagem capturada é útil, mas *não* impede a repetição dentro da janela Δ_a.

Janela deslizante de números de sequência. O mecanismo anti-repetição do IPsec ESP [**?**] mantém, por remetente, o maior número de sequência aceite h e um mapa de bits $W \in \{0,1\}^w$ (com $w = 64$ o valor recomendado), em que $W_i = 1$ significa que $h - i$ já foi recebido. Para uma mensagem autêntica com número $s > 0$:

$$\text{aceita}(s) \iff \begin{cases} s > h, & \text{e então } W \leftarrow (W \ll (s-h)) \mid 1, \quad h \leftarrow s; \\ 0 \le h - s < w \;\wedge\; W_{h-s} = 0, & \text{e então } W_{h-s} \leftarrow 1; \\ \text{falso}, & \text{se } h - s \ge w \text{ ou } W_{h-s} = 1. \end{cases} \tag{10}$$

O mecanismo tolera reordenação até w posições e rejeita duplicados e mensagens antigas. Duas condições são essenciais: o estado só pode ser atualizado *depois* de verificada a autenticidade (caso contrário um atacante avança a janela com números forjados), e cada chave deve pertencer a um único remetente.

2.5 Limitação de tráfego

O balde de testemunhos (*token bucket*) limita a taxa média a ρ mensagens por segundo, com rajadas até β. O número de testemunhos disponível no instante t, dado o estado no último acesso t_0, é

$$b(t) = \min\big(\beta,\; b(t_0) + \rho\,(t - t_0)\big), \tag{11}$$

e uma mensagem é aceite sse $b(t) \ge 1$, caso em que $b \leftarrow b(t) - 1$. Num intervalo de duração Δ, o número de mensagens aceites é limitado por $\beta + \rho\,\Delta$, independentemente da taxa oferecida.

2.6 Modelo de ameaças

Considera-se um adversário que pode (i) observar e alterar o tráfego na rede, (ii) ligar-se ao *broker* como cliente, subscrever, publicar e repetir mensagens, (iii) reivindicar a identidade de outro cliente, (iv) comprometer o próprio *broker* ou (v) comprometer um dispositivo legítimo, obtendo as suas chaves. A Tabela **??** organiza as ameaças segundo as categorias STRIDE, que correspondem às classes de problemas identificadas para o MQTT em [**?**].

Table 2. Ameaças ao MQTT segundo a classificação STRIDE e mecanismos que as mitigam.

Categoria	Ameaça no MQTT	Mitigação típica
Spoofing	Cliente reivindica a identidade de outro; mensagens injetadas em tópicos alheios	Autenticação (palavras-passe, mTLS); autenticação da mensagem; restrição chave–tópico
Tampering	Alteração do conteúdo, do cabeçalho ou do tópico em trânsito ou no *broker*	TLS (por salto); AEAD/MAC/assinatura com tópico nos dados associados (fim-a-fim)
Repudiation	Remetente nega ter enviado; recetor fabrica mensagens em nome do remetente	Assinaturas digitais (um MAC partilhado não basta)
Information disclosure	Subscrição de `#`; *broker* curioso; tópicos `$SYS`	ACL; cifra fim-a-fim; TEE no *broker* [**?**]
Denial of service	Inundação de mensagens; ligações lentas [**?**]; esgotamento de estado	Limitação de tráfego; limites de pacotes e ligações; estado limitado; IDS [**?**]
Elevation of privilege	Abuso de ACL baseadas em identidade não verificada; chave de um dispositivo usada para outros	ACL com identidade autenticada; restrição chave–tópico; revogação

Defesa em profundidade. Se um ataque tiver de ultrapassar n camadas de defesa independentes, cada uma contornável com probabilidade p_i, a probabilidade de sucesso é

$$P_{\text{sucesso}} = \prod_{i=1}^{n} p_i, \tag{12}$$

estritamente menor do que a de qualquer camada isolada sempre que $p_i < 1$. A hipótese de independência raramente se verifica por inteiro (por exemplo, o roubo de uma chave de dispositivo pode afetar várias camadas), mas o modelo justifica a combinação de mecanismos em camadas distintas: transporte, mensagem e disponibilidade.

3 Metodologia: protocolo da revisão sistemática

A revisão segue as diretrizes de Kitchenham e Charters para revisões sistemáticas em engenharia de *software* [**?**], organizadas em três fases (planeamento, condução e relato), e relata a seleção de estudos com o diagrama de fluxo PRISMA 2020 [**?**]. A Figura **??** resume o processo; as subsecções seguintes descrevem cada passo.

3.1 Definição do problema

O problema que a revisão procura esclarecer foi enunciado na Secção **??**: a especificação do MQTT deixa a proteção das mensagens à implementação, o TLS termina no *broker*, e a autenticação isolada não impede a repetição, a mudança de tópico nem o abuso de uma chave comprometida. Pretende-se identificar as melhores soluções do estado da arte académico atual para este problema, as propriedades que garantem e as lacunas que deixam.

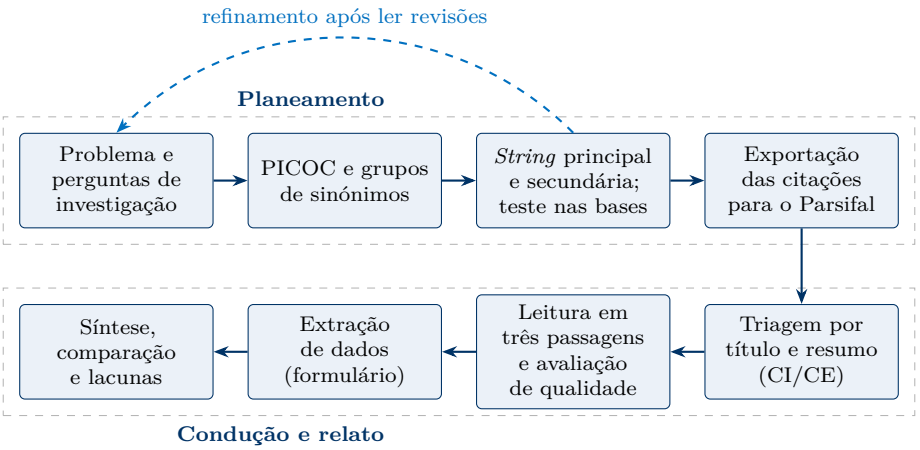


Figure 2. Processo da revisão sistemática adotado.

3.2 Perguntas de investigação

As perguntas organizam-se em três grupos (Tabela **??**): uma pergunta geral, que define *o que* se investiga; perguntas focadas, que procuram *como* os problemas são tratados; e perguntas estatísticas, que quantificam *quanto* é feito.

Table 3. Perguntas de investigação.

ID	Pergunta	Motivação
QG	Que mecanismos de segurança são propostos na literatura para proteger comunicações IoT baseadas em MQTT e que propriedades de segurança garantem?	Delimitar o estado da arte
QF1	Que ameaças e vulnerabilidades do MQTT são identificadas e como são demonstradas?	Modelo de ameaças de referência
QF2	Que mecanismos são propostos e em que ponto da arquitetura atuam (transporte, *broker*, mensagem fim-a-fim, deteção)?	Taxonomia das soluções
QF3	Que propriedades garantem (confidencialidade, integridade, autenticação, autorização, frescura e anti-repetição, não repúdio, disponibilidade, privacidade) e assumem um *broker* confiável?	Base da comparação
QF4	Como são avaliadas as soluções (protótipo, plataforma, métricas, verificação formal, dispositivos restritos)?	Maturidade da evidência
QF5	Que limitações e desafios em aberto são reportados?	Lacunas e trabalho futuro
QE1	Quantas publicações existem por ano?	Evolução do interesse
QE2	Qual a distribuição por tipo de publicação (revista, conferência, *workshop*)?	Maturidade da área
QE3	Quantos estudos abordam cada categoria e cada propriedade de segurança?	Identificar áreas pouco exploradas

3.3 Critérios PICOC

A Tabela **??** delimita o âmbito da revisão segundo os critérios PICOC.

3.4 *String* de pesquisa

Grupos de ideias e sinónimos. A partir das perguntas identificaram-se três grupos de ideias gerais, a cada um dos quais se associaram sinónimos (Tabela **??**). Os termos de um grupo

Table 4. Âmbito da revisão segundo os critérios PICOC.

Critério	Definição nesta revisão
Population	Comunicações IoT baseadas em MQTT ou MQTT-SN: clientes (sensores, atuadores, *gateways*) e *brokers*.
Intervention	Mecanismos de segurança: criptográficos (cifra, MAC, assinaturas, acordo de chaves), de autenticação e autorização, de proteção do *broker*, de deteção de ataques e de privacidade.
Comparison	MQTT com a segurança nativa (palavra-passe, ACL) ou apenas com TLS; comparação entre os mecanismos propostos.
Outcome	Propriedades de segurança garantidas, ameaças mitigadas, custo (latência, memória, energia, débito) e tipo de avaliação.
Context	Investigação académica com revisão por pares, publicada entre 2014 (normalização do MQTT 3.1.1 pela OASIS) e 2026, em ambientes IoT residenciais, industriais e de saúde.

combinam-se com `OR` e os grupos entre si com `AND`.

Table 5. Grupos de ideias e sinónimos usados na *string* de pesquisa.

Grupo	Termos (combinados com OR)
G1 — Protocolo	`"MQTT"`, `"MQTT-SN"`, `"MQ Telemetry Transport"`, `"Message Queuing Telemetry Transport"`, `"Message Queue Telemetry Transport"`
G2 — Segurança	`"security"`, `"secure"`, `"authentication"`, `"authorization"`, `"access control"`, `"encryption"`, `"confidentiality"`, `"integrity"`, `"privacy"`, `"attack*"`, `"vulnerabilit*"`, `"intrusion"`
G3 — Domínio	`"Internet of Things"`, `"IoT"`, `"IIoT"`, `"publish/subscribe"`, `"publish-subscribe"`, `"machine-to-machine"`, `"M2M"`
G4 — Revisões (só na secundária)	`"systematic literature"`, `"systematic review"`, `"literature review"`, `"survey"`

***String* principal.** A combinação dos grupos G1, G2 e G3, aplicada ao título, resumo e palavras-chave, é:

```
("MQTT" OR "MQTT-SN" OR "MQ Telemetry Transport" OR "Message Queuing Telemetry
Transport" OR "Message Queue Telemetry Transport")
AND ("security" OR "secure" OR "authentication" OR "authorization" OR "access
control" OR "encryption" OR "confidentiality" OR "integrity" OR "privacy" OR
"attack*" OR "vulnerabilit*" OR "intrusion")
AND ("Internet of Things" OR "IoT" OR "IIoT" OR "publish/subscribe" OR
"publish-subscribe" OR "machine-to-machine" OR "M2M")
```

***String* secundária.** Acrescentando o grupo G4 com mais um `AND`, obtém-se a *string* secundária, usada para encontrar revisões já publicadas sobre o tema. O termo `"survey"` foi acrescentado aos três propostos no protocolo base porque, nesta área, as revisões são publicadas maioritariamente com esse título (por exemplo, [**?**, **?**]). A leitura das revisões assim encontradas (Secção **??**) levou a dois refinamentos: inclusão de `"MQTT-SN"` e de `"intrusion"` na *string* principal, já que várias soluções visam a variante para redes de sensores [**?**, **?**] e a deteção de intrusões é uma linha de investigação própria [**?**, **?**]; e separação explícita das perguntas QF3 (propriedades) e QF4 (avaliação).

Bases de dados. Foram selecionadas as bases que indexam as principais revistas e conferências de segurança e redes: IEEE Xplore, Scopus, ACM Digital Library, Web of Science e ScienceDirect. A adaptação da *string* à sintaxe de cada uma consta do Anexo **??**. O teste revelou limitações que obrigaram a adaptações: o ScienceDirect não suporta o carácter universal ∗ e limita o número de operadores booleanos por campo, pelo que os termos truncados foram substituídos pelas formas singular e plural e a *string* foi dividida em consultas parciais; o IEEE Xplore limita o número de termos por pesquisa, pelo que se pesquisou nos metadados (título, resumo e palavras-chave) com os grupos completos. A Tabela **??** regista o número de registos devolvidos por cada base, executadas as pesquisas em [dd-mm-aaaa].

Table 6. Registos devolvidos pela *string* principal em cada base de dados.

Base de dados	Registos
IEEE Xplore	[n]
Scopus	[n]
ACM Digital Library	[n]
Web of Science	[n]
ScienceDirect	[n]
Total	[n]

3.5 Processo de pesquisa e ferramenta de apoio

As citações de todos os registos foram exportadas de cada base (formato BibTeX ou RIS) e importadas na ferramenta Parsifal, que remove duplicados e suporta a triagem, a avaliação de qualidade e a extração de dados por formulário, exportando no fim os dados extraídos em CSV.

3.6 Critérios de inclusão e exclusão

Um estudo é incluído se satisfizer *todos* os critérios de inclusão e *nenhum* dos de exclusão (Tabela **??**).

Table 7. Critérios de inclusão (CI) e de exclusão (CE).

ID	Critério
CI1	Propõe, implementa ou avalia um mecanismo de segurança para MQTT ou MQTT-SN, ou analisa ameaças e vulnerabilidades específicas do MQTT.
CI2	É um estudo primário publicado em revista, conferência ou *workshop* com revisão por pares.
CI3	Foi publicado entre 2014 e 2026.
CI4	O texto integral está acessível e escrito em inglês ou português.
CE1	O MQTT é apenas mencionado ou usado como transporte, sem contributo de segurança.
CE2	É uma versão preliminar de outro estudo incluído com o mesmo contributo (mantém-se a versão mais completa).
CE3	É literatura cinzenta: tese, relatório técnico, patente, apresentação ou artigo sem revisão por pares.
CE4	É uma revisão ou inquérito (analisado à parte como estudo secundário, Secção **??**).
CE5	Tem menos de quatro páginas ou não descreve o mecanismo com detalhe suficiente para ser avaliado.
CE6	Trata exclusivamente de outro protocolo (CoAP, AMQP, DDS) sem resultados para o MQTT.

Por aplicação do CE2, a versão em conferência do protocolo baseado em AugPAKE [?] foi excluída em favor da sua versão alargada em revista, o MQTT-Auth [?].

3.7 Seleção dos estudos e avaliação da qualidade

Primeira fase: título e resumo. Removidos os duplicados, cada registo foi classificado por dois revisores de forma independente, lendo apenas o título e o resumo, segundo os critérios da Tabela **??**. A concordância entre revisores foi medida com o coeficiente kappa de Cohen [?],

$$\kappa = \frac{p_o - p_e}{1 - p_e}, \qquad p_e = \sum_{c \in \{\text{inc},\text{exc}\}} \frac{n_{1c}}{N} \cdot \frac{n_{2c}}{N}, \tag{13}$$

onde p_o é a proporção de decisões coincidentes, p_e a concordância esperada por acaso, N o número de registos e n_{rc} o número de registos que o revisor r classificou na classe c. Obteve-se $\kappa =$ [0,00]; as divergências foram resolvidas por discussão.

Segunda fase: leitura em três passagens. Os estudos que passaram a primeira fase foram lidos segundo o método de Keshav [?]: a primeira passagem (título, resumo, introdução, títulos das secções e conclusões) confirma a categoria e a relevância; a segunda (texto completo, figuras e tabelas, ignorando demonstrações) permite reaplicar os critérios e avaliar a qualidade; a terceira, reservada aos estudos incluídos, reconstrói mentalmente o trabalho e alimenta a extração de dados.

Avaliação da qualidade. Cada estudo foi pontuado nos cinco critérios da Tabela **??**, com $q_{ij} \in \{0;\ 0{,}5;\ 1\}$ (não, em parte, sim). A pontuação do estudo i é

$$Q_i = \sum_{j=1}^{5} q_{ij}, \qquad 0 \le Q_i \le 5, \tag{14}$$

e foram excluídos os estudos com $Q_i < 2{,}5$.

Table 8. Critérios de avaliação da qualidade.

ID	Pergunta
QA1	O objetivo e o contributo estão claramente definidos?
QA2	O modelo de ameaças ou as propriedades de segurança pretendidas são explícitos?
QA3	O mecanismo (ou a análise) está descrito com detalhe suficiente para ser reproduzido?
QA4	Há avaliação experimental, analítica ou formal dos resultados?
QA5	As limitações e os custos são discutidos?

Fluxo de seleção. A Figura **??** apresenta o diagrama PRISMA 2020 do processo.

3.8 Extração de dados

Para responder às perguntas de investigação definiu-se o formulário de extração da Tabela **??**, preenchido no Parsifal para cada estudo incluído durante a terceira passagem de leitura. O resumo da extração consta do Anexo **??**.

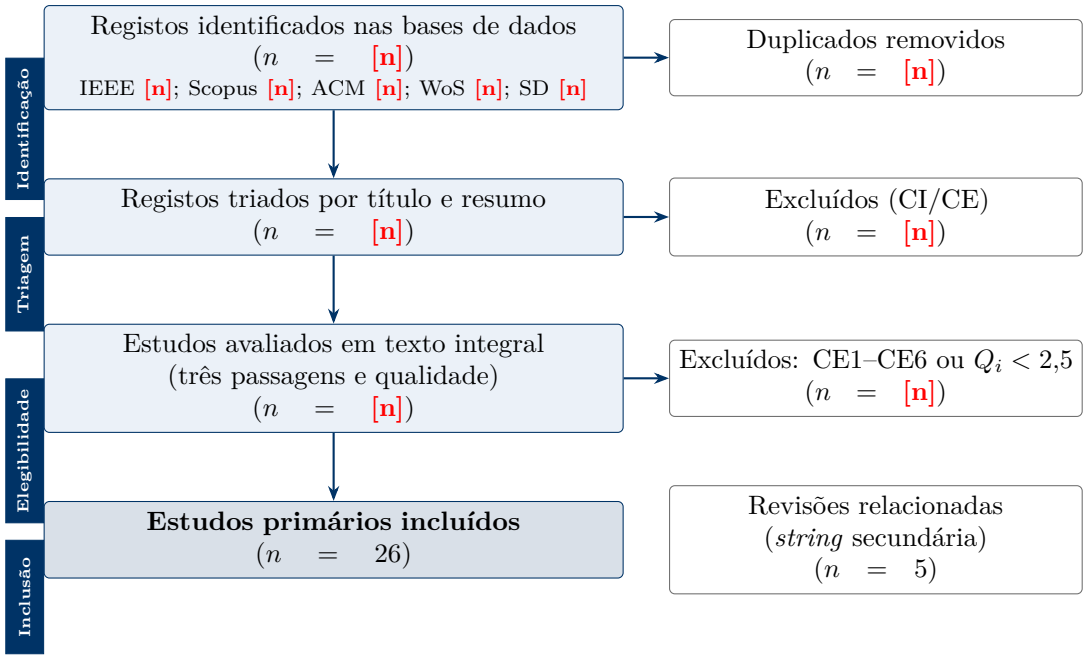


Figure 3. Diagrama de fluxo PRISMA 2020 da seleção dos estudos.

Table 9. Formulário de extração de dados e pergunta a que cada campo responde.

Campo	Valores	Pergunta
Ano; tipo de publicação	ano; revista / conferência / *workshop*	QE1, QE2
Tipo de contributo	análise de ameaças / mecanismo / avaliação / conjunto de dados	QF1, QF2
Categoria	uma das oito categorias da taxonomia (Secção **??**)	QF2, QE3
Ponto de atuação	transporte / *broker* / mensagem fim-a-fim / deteção	QF2
Primitivas	AES, ChaCha20-Poly1305, HMAC, ABE, ECC, RSA, PAKE, TEE, ML…	QF2
Propriedades	C, I, Au, Az, F/R, NR, D, P (ver Tabela **??**)	QF3, QE3
Confiança no *broker*	total / parcial / nenhuma	QF3
Avaliação	protótipo, plataforma, métricas, verificação formal	QF4
Dispositivos restritos	sim / não	QF4
Limitações declaradas	texto livre	QF5

4 Trabalhos relacionados: revisões existentes

A *string* secundária devolveu [n] registos, dos quais foram selecionadas para leitura as 5 revisões mais diretamente relacionadas com a segurança do MQTT. Esta secção resume-as, compara-as entre si e com a presente revisão (Tabela **??**) e justifica a necessidade de uma nova revisão.

4.1 Revisões analisadas

Perrone et al. (2017) [?]. Escrito na sequência dos ataques DDoS da botnet Mirai, analisa o MQTT enquanto protocolo concebido para dispositivos de baixa capacidade e descreve as soluções e melhorias de segurança habitualmente sugeridas e aplicadas em instalações reais. Os próprios autores caracterizam o levantamento de temas de investigação como **?**conciso, embora não exaustivo**?**.

Nebbione e Calzarossa (2020) [?]. Revisão abrangente da segurança dos protocolos da camada de aplicação da IoT, tanto de troca de mensagens (onde se inclui o MQTT) como de descoberta de serviços. Analisa as principais ameaças e as vulnerabilidades publicadas (CVE) de produtos e serviços, e boas práticas de mitigação. Conclui que a falta de serviços de segurança nos próprios protocolos, os erros de configuração e as limitações dos dispositivos tornam a segurança na camada de aplicação particularmente difícil.

Hintaw et al. (2023) [?]. Centrado no MQTT, organiza os problemas de segurança decorrentes do desenho do protocolo em negação de serviço, falsificação de identidade, divulgação de informação, elevação de privilégios e adulteração de dados, provocados por atacantes internos e externos, e revê as técnicas propostas para os tratar. Destaca como desafio em aberto o custo de processamento que a segurança acrescenta a dispositivos alimentados por bateria.

Lakshminarayana et al. (2024) [?]. Publicado na *IEEE Communications Surveys & Tutorials*, propõe uma classificação das vulnerabilidades do MQTT, categoriza os ataques segundo as características que explicam a sua execução e discute em detalhe os mecanismos de defesa, com ênfase em técnicas de identificação de vulnerabilidades e de deteção e prevenção de ataques, terminando com lições aprendidas e direções de investigação.

Laghari et al. (2024) [?]. Analisa a segurança do **?**ecossistema**?** MQTT — ataques prevalentes, consequências, estratégias de mitigação e investigação futura — e apresenta uma taxonomia de ataques. Os autores apontam às revisões anteriores uma discussão ampla mas superficial dos ataques e contramedidas e a omissão de componentes e papéis relevantes na construção de aplicações MQTT.

4.2 Comparação

A Tabela **??** compara as revisões segundo o âmbito, o tipo de análise e o que oferecem para lá do levantamento. As células assinaladas com – correspondem a aspetos que a revisão não reporta.

Table 10. Comparação das revisões relacionadas com a presente revisão. ✓ abordado; ● parcialmente; – não reportado.

Revisão	Ano	Só MQTT	Taxonomia de ataques	Revê defesas	Compara por propriedade	Protocolo RSL explícito	Propõe arquitetura
Perrone et al. [?]	2017	✓	–	✓	–	–	–
Nebbione e Calzarossa [?]	2020	●	✓	✓	–	–	–
Hintaw et al. [?]	2023	✓	✓	✓	–	–	–
Lakshminarayana et al. [?]	2024	✓	✓	✓	–	–	–
Laghari et al. [?]	2024	✓	✓	✓	–	–	–
Este trabalho	2026	✓	●	✓	✓	✓	✓

4.3 Posicionamento desta revisão

As revisões existentes estão organizadas sobretudo em torno dos *ataques*: classificam vulnerabilidades e associam-lhes contramedidas. Esta revisão distingue-se em quatro pontos:

1. **Protocolo explícito e reprodutível.** Perguntas de investigação, PICOC, *strings* por base de dados, critérios de inclusão, exclusão e qualidade, concordância entre revisores e diagrama PRISMA são relatados (Secção **??**), o que permite repetir e atualizar a revisão.

2. **Comparação por propriedade de segurança.** Os estudos são comparados segundo as propriedades que garantem à *mensagem* — incluindo frescura, anti-repetição e não repúdio — e segundo a confiança que depositam no *broker*, e não apenas segundo os ataques que mitigam (Secção **??**).

3. **Cobertura atualizada**, até 2026, incluindo trabalhos sobre anonimato [**?**], deteção distribuída de intrusões [**?**] e autenticação sem certificados [**?**].

4. **Ligação a uma proposta concreta.** As lacunas identificadas fundamentam uma arquitetura (Secção **??**) cuja implementação de referência está disponível publicamente [**?**].

5 Resultados da revisão

A Tabela **??** identifica os 26 estudos primários incluídos, numerados por ordem cronológica (E01–E26), com o tipo de publicação e a categoria que lhes foi atribuída na taxonomia da Secção **??**.

Table 11. Estudos primários incluídos. Tipo: R revista, C conferência, W *workshop*. Categorias: ver Figura **??**.

ID	Estudo	Ano	Tipo	Cat.	ID	Estudo	Ano	Tipo	Cat.
E01	Neisse et al. [**?**]	2014	C	C3	E14	Lohachab e Karambir [**?**]	2019	R	C2
E02	Singh et al. [**?**]	2015	C	C4	E15	Malina et al. [**?**]	2019	C	C5
E03	Niruntasukrat et al. [**?**]	2016	W	C3	E16	Sadio et al. [**?**]	2019	C	C5
E04	Shin et al. [**?**]	2016	C	C2	E17	Vaccari et al. [**?**]	2020	R	C1
E05	Rizzardi et al. [**?**]	2016	R	C3	E18	Vaccari et al. [**?**]	2020	R	C7
E06	Mektoubi et al. [**?**]	2016	C	C5	E19	Segarra et al. [**?**]	2020	C	C6
E07	Andy et al. [**?**]	2017	C	C1	E20	Dahlmanns et al. [**?**]	2021	W	C5
E08	Firdous et al. [**?**]	2017	C	C1	E21	Spielvogel et al. [**?**]	2021	W	C6
E09	Bisne e Parmar [**?**]	2017	C	C4	E22	Prantl et al. [**?**]	2021	C	C6
E10	Harsha et al. [**?**]	2018	C	C3	E23	Van Glabbeek et al. [**?**]	2022	R	C5
E11	Calabretta et al. [**?**]	2018	R	C3	E24	Buccafurri et al. [**?**]	2023	R	C8
E12	Hernández Ramos et al. [**?**]	2018	R	C1	E25	Alotaibi et al. [**?**]	2024	R	C7
E13	Dinculeană e Cheng [**?**]	2019	R	C5	E26	Javadi et al. [**?**]	2026	R	C2

5.1 Caracterização dos estudos (QE1, QE2)

Publicações por ano (QE1). A Figura **??** mostra a distribuição temporal. O interesse surge com a normalização do MQTT 3.1.1 (2014) e atinge o máximo entre 2016 e 2021, período em que se concentram $4+3+3+4+3+3 = 20$ dos 26 estudos (76,9 %). A partir de 2022 o número de estudos incluídos por ano diminui, mas os trabalhos mais recentes deslocam-se de mecanismos básicos de

autenticação para problemas mais específicos: segurança muitos-para-muitos, anonimato, deteção distribuída e autenticação sem certificados.

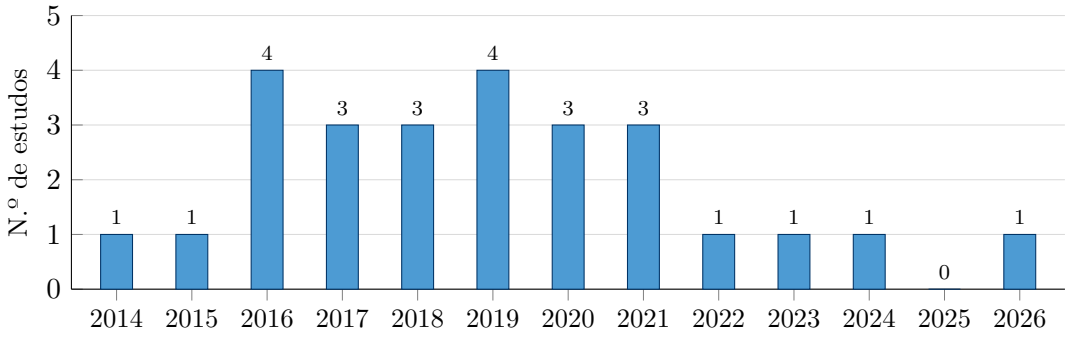


Figure 4. Número de estudos primários incluídos por ano de publicação ($n = 26$).

Tipo de publicação (QE2). Doze estudos (46,2 %) foram publicados em conferências, onze (42,3 %) em revistas e três (11,5 %) em *workshops*. A proporção de revistas cresce ao longo do período: dos dez estudos publicados desde 2020, seis (60 %) são artigos de revista, contra cinco dos dezasseis anteriores (31,3 %), o que sugere uma área em consolidação.

5.2 Taxonomia das soluções (QF2)

Os estudos foram agrupados em oito categorias segundo o *ponto de atuação* do mecanismo e o *objetivo* principal (Figura **??**). Cada estudo foi atribuído à categoria do seu contributo principal.

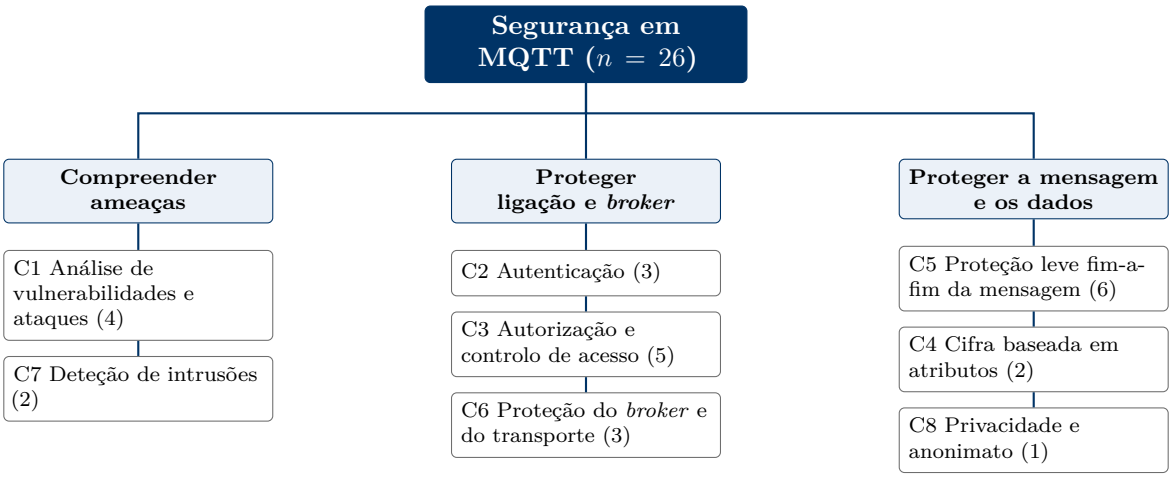


Figure 5. Taxonomia dos estudos incluídos, com o número de estudos por categoria.

5.2.1 C1 — Análise de vulnerabilidades e ataques

Estes estudos fundamentam o modelo de ameaças. Andy et al. [**?**] observam que, por omissão, o MQTT só oferece autenticação e não cifra os dados em trânsito, e demonstram cenários de ataque que comprometem a privacidade, a autenticação e a integridade. Firdous et al. [**?**] apresentam um modelo de ameaças para ambientes MQTT e avaliam ataques de negação de serviço contra *brokers*. Hernández Ramos et al. [**?**] propõem uma técnica de *fuzzing* baseada em modelos para

testar implementações do protocolo. Vaccari et al. [?] identificam uma fraqueza que permite ao cliente configurar o comportamento do servidor e exploram-na no SlowITe, um ataque de negação de serviço de baixa taxa, eficaz contra serviços reais com e sem cifra e com poucos recursos do atacante. Harsha et al. [?] (classificado em C3) mostram ainda, com a API do Shodan, a exposição de *brokers* acessíveis na Internet. Em conjunto, estes trabalhos mostram que as ameaças relevantes vão da escuta e injeção triviais em *brokers* mal configurados até à negação de serviço por ligações lentas, que nem a cifra evita.

5.2.2 C2 — Autenticação

Shin et al. [?] propõem um enquadramento de segurança para o MQTT baseado no AugPAKE, um acordo de chaves autenticado por palavra-passe. Lohachab e Karambir [?] apresentam um esquema leve de autenticação e autorização entre dispositivos, baseado em ECC e MQTT, implementado e comparado com outros esquemas. Javadi et al. [?] propõem o CMAP, um protocolo de autenticação mútua sem certificados nem autoridade de certificação, sobre curvas elípticas, que preserva confidencialidade e integridade; o protocolo é verificado formalmente, avaliado em Raspberry Pi com o *broker* Mosquitto (338 ms de latência de autenticação contra 713 ms com TLS) e simulado em NS-3 com nós fixos e móveis.

5.2.3 C3 — Autorização e controlo de acesso

Neisse et al. [?] integram no MQTT o SecKit, uma ferramenta de segurança baseada em modelos que aplica regras de política sobre os fluxos de dados, motivada pela proteção da privacidade. Niruntasukrat et al. [?] adaptam o OAuth 1.0a ao MQTT, tendo em conta os recursos limitados dos nós, a ausência de interface de utilizador e a distribuição de chaves, e mostram atrasos de autorização e *overhead* mínimos numa plataforma real. Rizzardi et al. [?] estendem o MQTT com um enquadramento de gestão de chaves e outro de aplicação de políticas (AUPS, disponível em código aberto). Harsha et al. [?] implementam autenticação e ACL num *broker* em Raspberry Pi e verificam que os ataques estudados deixam de ter efeito. Calabretta et al. [?] propõem o MQTT-Auth: o AugPAKE garante a confidencialidade e dois *tokens* autenticam a utilização de um tópico e autorizam o acesso a ele, com extensão a hierarquias de tópicos (versão alargada de [?]).

5.2.4 C4 — Cifra baseada em atributos

Singh et al. [?] propõem o SMQTT e o SMQTT-SN, que acrescentam ao MQTT cifra baseada em atributos com política na chave ou no criptograma (KP/CP-ABE) sobre ECC leve: o *publisher* cifra para um conjunto de atributos e só os subscritores com atributos compatíveis decifram. Bisne e Parmar [?] combinam ABE com AES de *S-box* dinâmica. A ABE resolve elegantemente a confidencialidade de grupo (um criptograma, vários destinatários), mas tem um custo computacional elevado para dispositivos restritos.

5.2.5 C5 — Proteção leve fim-a-fim da mensagem

É a categoria mais numerosa. Mektoubi et al. [?] comparam RSA e curvas elípticas para proteger a comunicação MQTT. Dinculeană e Cheng [?] propõem o mapeamento *Value-to-HMAC*, que envia valores sob a forma de HMAC em vez de os cifrar, garantindo confidencialidade e integridade com um único mecanismo e com melhor desempenho do que uma cifra simétrica. Malina et al. [?] propõem três níveis de segurança: mensagens não adulteradas, proteção da privacidade das fontes e dos recetores, e segurança de longo prazo com autenticação mútua de todas as partes. Sadio et al. [?] adotam a AEAD ChaCha20-Poly1305 para cifra fim-a-fim em MQTT e MQTT-SN, com um protótipo em Arduino UNO de pequena pegada de memória. Dahlmanns et al. [?] propõem o ENTRUST, segurança fim-a-fim baseada num servidor de chaves que garante confidencialidade, integridade e autenticação sem qualquer alteração ao protocolo. Van Glabbeek et al. [?] propõem uma solução para comunicação muitos-para-muitos que, face ao MQTTS (MQTT sobre TLS), reduz em 80 % o *overhead* de comunicação e em 40 % o computacional no estabelecimento de uma ligação segura do lado do cliente.

5.2.6 C6 — Proteção do *broker* e do transporte

Segarra et al. [?] executam o *broker* dentro de um ambiente de execução confiável (ARM TrustZone), com um *handshake* baseado em TLS mútuo e cifra em duas camadas, usando o TEE como intermediário confiável; avaliam o protótipo com micro e macro *benchmarks* e cargas reais de uma aplicação médica. Spielvogel et al. [?] observam que um *broker* que aceita ligações seguras e inseguras reencaminha mensagens independentemente da proteção de cada salto, e propõem que o *publisher* possa exigir que a mensagem só seja entregue por ligações com o nível de segurança pretendido. Prantl et al. [?] medem o impacto do TLS no débito, no tempo de estabelecimento de ligação e na eficiência energética num microcontrolador, e concluem que esse impacto depende sobretudo das condições da rede e da frequência de restabelecimento de ligações.

5.2.7 C7 — Deteção de intrusões

Vaccari et al. [?] publicam o MQTTset, um conjunto de dados de tráfego MQTT legítimo e de ataques para treinar sistemas de deteção baseados em aprendizagem automática. Alotaibi et al. [?] usam um enquadramento distribuído (H2O) para monitorizar e classificar em tempo real comportamentos anómalos no MQTT, obtendo os melhores resultados com XGBoost.

5.2.8 C8 — Privacidade e anonimato

Buccafurri et al. [?] propõem o MQTT-A, que estende o mecanismo de *bridging* do MQTT com uma rede de *brokers* intermédios para que o *broker* final não consiga identificar a origem nem o destino, com um mecanismo de descoberta de tópicos que preserva o anonimato e sem alterações à infraestrutura MQTT normalizada.

5.3 Comparação dos mecanismos (QF3, QF4)

A Tabela **??** compara os 22 estudos que propõem mecanismos (categorias C2 a C8) segundo as propriedades de segurança garantidas, a confiança depositada no *broker*, o tipo de avaliação e a consideração de dispositivos restritos. Os quatro estudos de análise (C1) não propõem mecanismos e foram discutidos na secção anterior.

Cobertura das propriedades (QE3). A Figura **??** contabiliza, para os 22 mecanismos, quantos garantem cada propriedade (total ou parcialmente). A confidencialidade é a propriedade mais tratada (15 estudos), seguida da autenticação (9) e da autorização (8). A integridade é reportada explicitamente apenas por 7 estudos, e apenas 6 funcionam, total ou parcialmente, com um *broker* não confiável. A frescura, a proteção contra repetição e o não repúdio não são reportados como propriedades garantidas por nenhum dos estudos, na informação extraída.

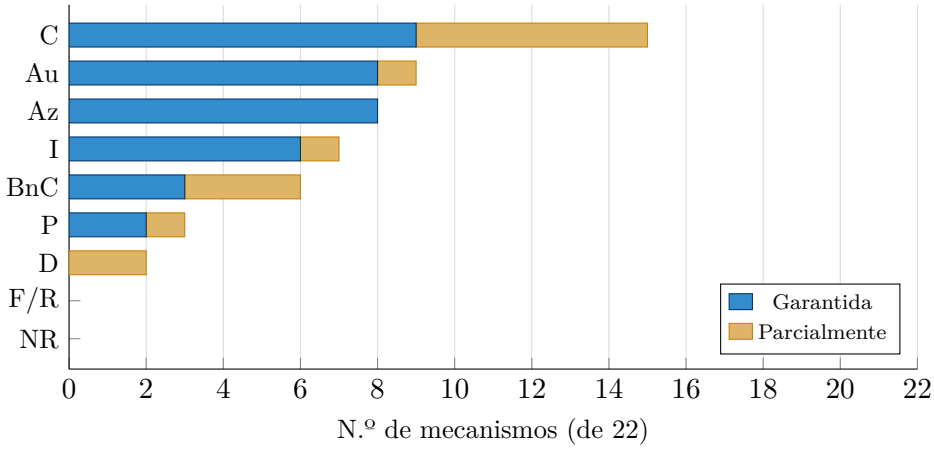


Figure 6. Número de mecanismos que garantem cada propriedade de segurança (siglas como na Tabela **??**).

Avaliação (QF4). Quinze dos 22 mecanismos (68,2 %) reportam avaliação experimental, mas só um combina avaliação experimental com verificação formal e simulação [**?**], e só um usa uma avaliação predominantemente analítica [**?**]. Nove mecanismos são desenhados ou avaliados explicitamente para dispositivos restritos, com plataformas que vão do Arduino UNO [**?**] a microcontroladores comerciais [**?**] e ao Raspberry Pi [**?**]. As métricas mais comuns são latência, memória, tempo de execução e *overhead* de comunicação; nenhum estudo mede, lado a lado, o custo de cada mecanismo e os ataques que esse mecanismo efetivamente impede.

5.4 Respostas às perguntas de investigação

QG. A literatura propõe mecanismos em três frentes: compreender as ameaças (análise de vulnerabilidades, *fuzzing*, deteção de intrusões), proteger a ligação e o *broker* (autenticação, autorização, TEE, políticas de transporte) e proteger a mensagem (cifra leve fim-a-fim, MAC, ABE, anonimato). A confidencialidade, a autenticação e a autorização estão bem cobertas; a integridade explícita, a independência face ao *broker* e, sobretudo, a frescura, a anti-repetição e o não repúdio estão pouco representadas.

Table 12. Comparação dos estudos que propõem mecanismos. Propriedades: C confidencialidade, I integridade, Au autenticação, Az autorização, F/R frescura e anti-repetição, NR não repúdio, D disponibilidade/deteção, P privacidade. BnC: funciona com *broker* não confiável. Aval.: E experimental, F formal, S simulação, A analítica. Restr.: avaliado ou desenhado para dispositivos restritos. ✓ garantido; ● parcialmente; ✗ não, por desenho; – não reportado.

ID	Estudo	Mecanismo principal	C	I	Au	Az	F/R	NR	D	P	BnC	Aval.	Restr.
C2 — Autenticação													
E04	Shin et al. [?]	AugPAKE (acordo de chaves por palavra-passe)	●	–	✓	–	–	–	–	–	–	–	–
E14	Lohachab e Karambir [?]	Autenticação e autorização com ECC	–	–	✓	✓	–	–	–	–	–	E	✓
E26	Javadi et al. [?]	Autenticação mútua sem certificados (ECC)	✓	✓	✓	–	–	–	–	–	–	F, E, S	✓
C3 — Autorização e controlo de acesso													
E01	Neisse et al. [?]	Políticas de uso (SecKit)	–	–	–	✓	–	–	–	●	–	E	–
E03	Niruntasukrat et al. [?]	OAuth 1.0a adaptado	–	–	●	✓	–	–	–	–	–	E	✓
E05	Rizzardi et al. [?]	Gestão de chaves e políticas (AUPS)	●	–	–	✓	–	–	–	–	–	–	–
E10	Harsha et al. [?]	Autenticação e ACL no *broker*	–	–	✓	✓	–	–	–	–	✗	E	–
E11	Calabretta et al. [?]	AugPAKE e *tokens* por tópico	✓	–	✓	✓	–	–	–	–	–	A	–
C4 — Cifra baseada em atributos													
E02	Singh et al. [?]	KP/CP-ABE sobre ECC	✓	–	–	✓	–	–	–	–	●	–	✓
E09	Bisne e Parmar [?]	ABE e AES de *S-box* dinâmica	✓	–	–	✓	–	–	–	–	–	–	–
C5 — Proteção leve fim-a-fim da mensagem													
E06	Mektoubi et al. [?]	RSA vs. curvas elípticas	●	–	–	–	–	–	–	–	–	–	–
E13	Dinculeană e Cheng [?]	Mapeamento *Value-to-HMAC*	✓	✓	–	–	–	–	–	–	✓	E	✓
E15	Malina et al. [?]	Três níveis de segurança	●	✓	✓	–	–	–	–	✓	–	–	✓
E16	Sadio et al. [?]	AEAD ChaCha20-Poly1305	✓	✓	–	–	–	–	–	–	✓	E	✓
E20	Dahlmanns et al. [?]	Servidor de chaves (ENTRUST)	✓	✓	✓	–	–	–	–	–	✓	E	–
E23	Van Glabbeek et al. [?]	Segurança muitos-para-muitos	●	●	–	–	–	–	–	–	●	E	✓
C6 — Proteção do broker e do transporte													
E19	Segarra et al. [?]	*Broker* em TEE (TrustZone)	✓	–	✓	–	–	–	–	–	●	E	–
E21	Spielvogel et al. [?]	Nível de segurança exigido por salto	●	–	–	–	–	–	–	–	✗	E	–
E22	Prantl et al. [?]	Avaliação do MQTT sobre TLS	✓	✓	–	–	–	–	–	–	✗	E	✓
C7 — Deteção de intrusões													
E18	Vaccari et al. [?]	Conjunto de dados para IDS	–	–	–	–	–	–	●	–	–	E	–
E25	Alotaibi et al. [?]	IDS distribuído (H2O, XGBoost)	–	–	–	–	–	–	●	–	–	E	–
C8 — Privacidade e anonimato													
E24	Buccafurri et al. [?]	Rede de *bridges* anónima	–	–	–	–	–	–	–	✓	–	E	–

QF1. As ameaças identificadas são: escuta e injeção em *brokers* mal configurados ou expostos na Internet [**?**, **?**]; negação de serviço, incluindo ataques de baixa taxa que a cifra não evita [**?**, **?**]; erros de implementação detetáveis por *fuzzing* [**?**]; e o *broker* como ponto de exposição de todo o conteúdo [**?**, **?**].

QF2. Os mecanismos atuam: no transporte e na ligação (TLS e a sua avaliação, políticas por salto); no *broker* (ACL, OAuth, políticas, TEE); na mensagem, de ponta a ponta (ABE, AEAD, HMAC, servidor de chaves); e fora do caminho de dados (deteção de intrusões). A proteção fim-a-fim é a categoria mais numerosa (C5, seis estudos).

QF3. Ver a Tabela **??** e a Figura **??**. Apenas seis mecanismos dispensam, total ou parcialmente, a confiança no *broker*; os restantes assumem-no confiável ou não o discutem.

QF4. A avaliação é maioritariamente experimental, em plataformas reais ou de baixo custo, centrada no custo do mecanismo; a verificação formal é rara.

QF5. As limitações e desafios mais referidos são o custo da segurança em dispositivos alimentados por bateria [**?**], a inadequação do TLS a nós restritos [**?**, **?**], a exposição do conteúdo no *broker* [**?**] e a impossibilidade de um cliente impor a proteção dos restantes saltos [**?**].

QE1–QE3. Ver a Figura **??**, a Secção **??** e a Figura **??**.

6 Proposta: arquitetura de segurança em camadas

Esta secção propõe uma arquitetura que responde às lacunas identificadas na Secção **??**. A proposta é apresentada ao nível do desenho e da sua formalização; a avaliação experimental (custo de cada camada e ataques que cada uma impede) é objeto da segunda parte do projeto. Uma implementação de referência em C++23, com documentação técnica completa, está disponível no repositório do projeto [**?**].

6.1 Princípios de desenho

D1. Defesa em profundidade (Eq. **??**): proteção no transporte, na mensagem e na disponibilidade, de forma independente.

D2. O *broker* não é de confiança para o conteúdo: a confidencialidade, a integridade, a autenticidade e a frescura das mensagens não podem depender dele.

D3. Camadas independentes e comutáveis: cada mecanismo é uma camada que pode ser ativada ou desativada sem alterar as restantes, o que permite medir isoladamente o custo e o benefício de cada um.

D4. Verificações baratas primeiro, estado só depois da autenticação: rejeitar cedo o que é barato rejeitar e nunca deixar entrada não autenticada alterar estado.

D5. Estado limitado: toda a estrutura que um atacante consiga fazer crescer tem um limite superior.

6.2 Arquitetura em camadas

A comunicação de cada extremo (sensor, *gateway*) passa por uma sequência ordenada de camadas entre a aplicação e o transporte MQTT (Figura **??**). Seja $\mathcal{M}$ o conjunto das mensagens e $\perp$ a rejeição. Cada camada ℓ_i define duas funções $\ell_i^{\uparrow}, \ell_i^{\downarrow} : \mathcal{M} \to \mathcal{M} \cup \{\perp\}$, com $\ell(\perp) = \perp$. Para camadas ordenadas do lado da aplicação (ℓ_1) para o lado do transporte (ℓ_n):

$$\text{Saída}(m) = \ell_n^{\downarrow} \circ \cdots \circ \ell_1^{\downarrow}(m), \tag{15}$$

$$\text{Entrada}(m) = \ell_1^{\uparrow} \circ \cdots \circ \ell_n^{\uparrow}(m). \tag{16}$$

A primeira rejeição interrompe o processamento: uma mensagem recebida que alguma camada rejeite nunca chega à aplicação. A *ordem* das camadas tem significado: com a persistência acima da segurança guarda-se texto em claro; abaixo dela, guardam-se envelopes (cifra em repouso); a limitação de tráfego fica junto ao transporte para descartar inundações antes de qualquer operação criptográfica.

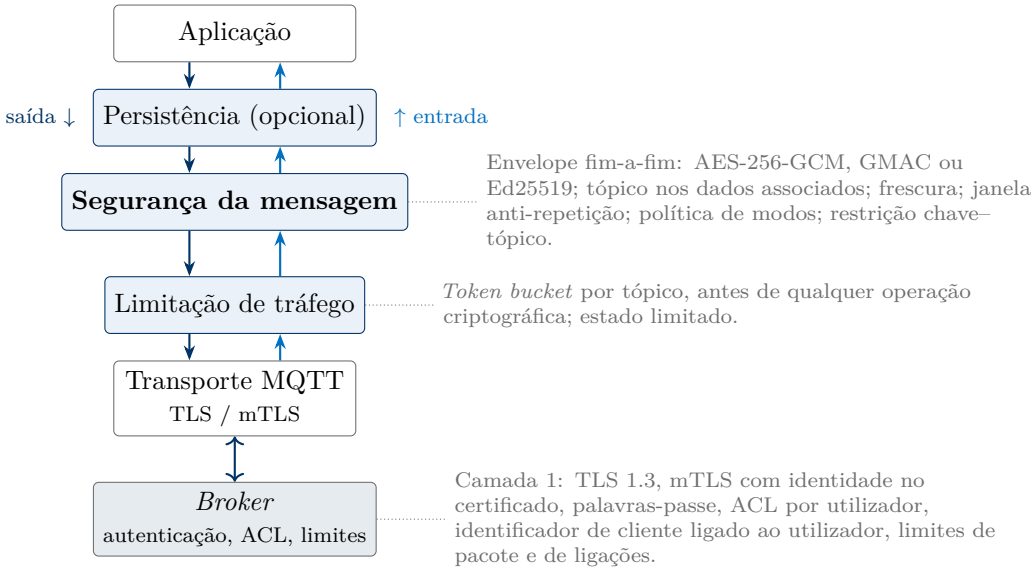


Figure 7. Arquitetura proposta: camadas entre a aplicação e o transporte, cada uma comutável de forma independente. A saída percorre as camadas de cima para baixo e a entrada de baixo para cima.

6.3 Camada de transporte e *broker*

A primeira camada usa o que os *brokers* já oferecem (Tabela **??**), configurado de forma restritiva: só a porta TLS aberta (TLS 1.3); autenticação mútua por certificado, com o nome comum do certificado como identidade MQTT; palavras-passe; ACL de negação por omissão com regras parametrizadas pelo utilizador autenticado (por exemplo, `restricted/sensors/%u/#` só para escrita); identificador de cliente igual ao nome de utilizador, o que impede um cliente de tomar a sessão de outro; desativação de `$SYS`; e limites de tamanho de pacote e de número de ligações.

Esta camada protege a rede e restringe quem fala com o *broker*, mas, por si só, deixa intactos os problemas P1 a P3.

6.4 Envelope fim-a-fim

A camada de segurança substitui o conteúdo de cada mensagem por um *envelope* (Figura **??**), com cabeçalho fixo de 25 octetos.

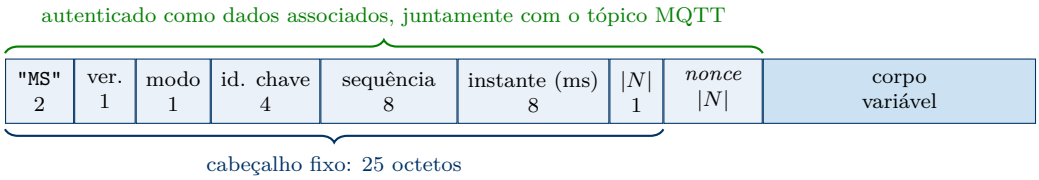


Figure 8. Formato do envelope (inteiros em *big-endian*); o número sob cada campo é o seu tamanho em octetos.

Dados associados e ligação ao tópico. Sendo cab o cabeçalho, N o *nonce* e τ o tópico MQTT, os dados associados são

$$A = cab \,\|\, N \,\|\, \mathrm{u16}(|\tau|) \,\|\, \tau. \tag{17}$$

Como o tópico entra na autenticação mas não no envelope, uma mensagem válida republicada noutro tópico falha a verificação sem qualquer custo de transmissão; e como todo o cabeçalho (incluindo o modo, o identificador da chave, a sequência e o instante) é autenticado, nenhum desses campos pode ser alterado.

Modos de proteção. O remetente escolhe um de três modos, indicado no cabeçalho:

$$\textbf{cifra:} \quad corpo = C \,\|\, T, \qquad (C, T) = \text{AES-GCM.Enc}(K, N, P, A); \tag{18}$$

$$\textbf{autenticação:} \quad corpo = P \,\|\, T, \qquad T = \text{AES-GCM.Enc}(K, N, \varnothing, A \,\|\, P); \tag{19}$$

$$\textbf{assinatura:} \quad corpo = P \,\|\, \sigma, \qquad \sigma = \text{Ed25519.Sign}(sk, A \,\|\, P),\ N = \varnothing. \tag{20}$$

O modo de cifra garante confidencialidade e integridade; o de autenticação (GMAC) garante integridade com o conteúdo legível; o de assinatura garante integridade e *prova de origem*: o recetor guarda apenas chaves públicas e, por isso, consegue verificar, mas não forjar, mensagens dos dispositivos. O custo fixo por mensagem é

$$\omega(\text{modo}) = 25 + |N| + |T| = \begin{cases} 25 + 12 + 16 = 53 \text{ octetos} & \text{(cifra, autenticação)}, \\ 25 + 0 + 64 = 89 \text{ octetos} & \text{(assinatura)}. \end{cases} \tag{21}$$

Política do recetor contra a redução do nível de proteção. Cada recetor mantém o conjunto $\mathcal{A} \subseteq \{\text{cifra}, \text{autenticação}, \text{assinatura}\}$ dos modos que aceita e rejeita qualquer envelope cujo modo $\mu \notin \mathcal{A}$. Como μ faz parte de A, um atacante não consegue rotular uma mensagem

cifrada como **?**apenas autenticada**?** sem invalidar a etiqueta, e um detentor de chave não consegue baixar o nível de proteção abaixo do que o recetor exige.

6.5 Ordem de verificação no recetor

A Tabela **??** define a sequência de verificações de um envelope recebido. A ordem decorre do princípio D4.

Table 13. Sequência de verificações de um envelope recebido.

#	Verificação	Justificação da posição	Rejeição
1	Formato do envelope	Descarta conteúdo não protegido (por exemplo, injeções em claro)	mensagem malformada
2	Modo $\mu \in \mathcal{A}$	Barato; o modo está em A, pelo que mentir sobre ele só pode falhar	modo não aceite
3	Frescura, Eq. (**??**)	Barato; o instante está em A, pelo que alterá-lo invalida a etiqueta	mensagem expirada
4	Chave conhecida e verificação criptográfica	A partir daqui a mensagem é autêntica; a falha é sempre a mesma, sem revelar a causa (sem oráculo)	falha de autenticação
5	Restrição chave–tópico, Eq. (**??**)	Só depois da autenticação: entrada não autenticada não pode sondar a política	permissão negada
6	Janela anti-repetição, Eq. (**??**)	Só depois da autenticação (números forjados não avançam a janela) e da restrição (uma mensagem recusada não consome o seu número)	repetição detetada

6.6 Frescura e anti-repetição

A frescura usa a Eq. (**??**) com $\Delta_a = 60$ s e $\Delta_s = 5$ s, e a anti-repetição a janela da Eq. (**??**) com $w = 64$, mantida por identificador de chave. Os dois mecanismos são complementares: a frescura sozinha deixa passar todas as repetições com menos de Δ_a; a janela sozinha não protege contra a perda do seu estado (por exemplo, reinício do recetor), situação em que a frescura limita a exposição a Δ_a. Para cumprir o princípio D5, o número de janelas é limitado e um identificador de chave novo é recusado quando o limite é atingido. Os limites do GCM (Eq. (**??**)) e do espaço de sequências (2^{64}) impõem a rotação das chaves.

6.7 Restrição chave–tópico

Autenticar uma mensagem prova apenas que foi produzida com a chave k. Para que um dispositivo comprometido não publique, com a sua chave válida, nos tópicos dos outros (problema P3), cada chave tem um dono dono(k) e o recetor aplica regras de negação por omissão. Sendo F_k as regras específicas da chave, F_* os padrões gerais e σ_k a substituição $\{\texttt{\%u} \mapsto \text{dono}(k),\ \texttt{\%k} \mapsto k\}$:

$$\text{autorizada}(k, \tau) \iff \exists f \in F_k \cup \sigma_k(F_*) :\ \text{corr}(f, \tau), \tag{22}$$

com corr definida na Eq. (**??**). Por exemplo, com o padrão `+/sensors/%u/#`, a chave de `sensor-7` só pode publicar em `open/sensors/sensor-7/...` e `restricted/sensors/sensor-7/...`. O dono tem de ser um único nível de tópico sem carateres especiais, para que a substituição não alargue o filtro.

6.8 Gestão de chaves

Cada dispositivo d tem, por época e, uma chave AES, um par de chaves Ed25519 e o identificador $\mathrm{id}(d, e) = e \cdot 10^6 + d$ (o *gateway* é $d = 0$). Identificadores nunca são reutilizados: um identificador reutilizado teria uma janela anti-repetição nova, na qual mensagens antigas voltariam a ser aceites. A Tabela **??** mostra que chaves cada papel detém.

Table 14. Distribuição de chaves por papel.

Papel	**Chaves AES**	**Chaves privadas Ed25519**	**Chaves públicas Ed25519**
Gateway	de todos os dispositivos e a sua	**apenas a sua**	de todos os dispositivos e a sua
Dispositivo d	a sua e a do *gateway* (ordens)	a sua	a do *gateway*
Atacante	—	—	— (apenas o certificado da CA)

A **rotação** instala as chaves da época $e + 1$ ao lado das da época e, muda os remetentes para as novas e revoga as antigas após um período de graça. A **revogação** de um dispositivo remove as suas chaves de mensagem, a sua palavra-passe no *broker* e coloca o seu certificado na CRL, atuando nas duas camadas de defesa.

6.9 Limitação de tráfego antes da criptografia

Junto ao transporte, uma camada aplica a Eq. (**??**) por tópico, rejeitando o excesso antes de qualquer verificação criptográfica. O número de baldes é limitado; quando o limite é atingido, os baldes inativos (que voltariam a estar cheios) são descartados e, se não houver nenhum, os tópicos novos partilham um único balde, pelo que um atacante não consegue criar orçamento inventando tópicos.

6.10 Mapeamento entre ameaças e mecanismos

A Tabela **??** relaciona as ameaças da Tabela **??** com os mecanismos da proposta.

6.11 Comparação com os trabalhos relacionados

A Tabela **??** compara a proposta com os mecanismos fim-a-fim e de autenticação mais próximos, acrescentando às propriedades da Tabela **??** três mecanismos específicos desta proposta: ligação ao tópico (LT), política contra a redução do nível de proteção (RN) e restrição chave–tópico (CT).

A proposta não supera os trabalhos relacionados em todas as dimensões: não oferece anonimato [**?**], não protege o próprio *broker* com um TEE [**?**], não oferece confidencialidade de grupo por atributos [**?**] e não tem verificação formal [**?**]. O seu contributo está na *combinação*, numa só camada fim-a-fim, de propriedades que a literatura analisada trata separadamente ou não reporta (ligação ao tópico, frescura com anti-repetição, política contra a redução do nível de proteção, restrição chave–tópico e não repúdio opcional) e na organização em camadas comutáveis, que permite medir o custo e o benefício de cada mecanismo isoladamente.

Table 15. Ameaças e mecanismos da arquitetura proposta.

Ameaça	**Mecanismo**	**Camada**
Escuta na rede	TLS 1.3	transporte
Escuta pelo *broker* ou por subscritores de `#`	Modo de cifra; ACL	mensagem; *broker*
Adulteração do conteúdo ou do cabeçalho	Etiqueta GCM ou assinatura sobre $A \,\|\|\, P$	mensagem
Republicação noutro tópico	Tópico em A, Eq. (**??**)	mensagem
Repetição	Janela anti-repetição	mensagem
Mensagens antigas	Frescura	mensagem
Injeção de mensagens em claro	Formato do envelope e autenticação	mensagem
Redução do nível de proteção	Modo em A e política $\mathcal{A}$	mensagem
Usurpação de identidade no *broker*	Palavras-passe, mTLS, identificador ligado ao utilizador	transporte
Dispositivo comprometido a publicar por outros	Restrição chave–tópico, Eq. (**??**); ACL com `%u`	mensagem; *broker*
Recetor a forjar dados de dispositivos	Modo de assinatura (recetor só com chaves públicas)	mensagem
Chaves roubadas	Rotação por épocas; revogação	gestão
Inundação de um tópico	*Token bucket* antes da criptografia; limites no *broker*	disponibilidade
Esgotamento de memória	Estado limitado (janelas, baldes, repositório)	todas
Oráculo de verificação	Falha uniforme; estado só depois da autenticação	mensagem

6.12 Limitações conhecidas

- **Chaves pré-partilhadas**: a distribuição inicial das chaves assume um canal seguro; um acordo de chaves por dispositivo (por exemplo, ECDH) eliminaria os segredos pré-partilhados.
- **Chave de grupo nas ordens**: nos modos AES todos os atuadores detêm a chave do *gateway*, pelo que um atuador comprometido pode forjar ordens para os outros; o modo de assinatura resolve-o, a um custo computacional superior.
- **Limitação por tópico**: o tópico é escolhido por quem publica, pelo que um atacante que inunde o tópico de uma vítima consome também o orçamento da vítima; limites por cliente pertencem ao *broker*.
- **Estado da janela não persistente**: o reinício do recetor apaga as janelas anti-repetição, ficando a proteção limitada à frescura (Δ_a).
- **Dados falsos mas autênticos**: um dispositivo comprometido continua a poder publicar dados falsos nos seus próprios tópicos; só a deteção e a revogação o travam.

6.13 Plano de avaliação (segunda parte do projeto)

A avaliação experimental medirá, para cada combinação de camadas: (i) o custo, em latência fim-a-fim, tempo de processador por mensagem, débito e octetos acrescentados (Eq. **??**); e (ii) o benefício, como a fração de ataques bem-sucedidos (escuta, injeção, repetição, mudança de tópico, usurpação de identidade, inundação) com cada defesa ativa ou inativa. Esta medição conjunta de custo e benefício responde diretamente à lacuna identificada na QF4.

Table 16. Posicionamento da proposta face aos trabalhos relacionados mais próximos. Siglas e símbolos como na Tabela **??**; LT ligação ao tópico; RN política contra a redução do nível de proteção; CT restrição chave–tópico; Com.: camadas comutáveis em tempo de execução.

ID	Trabalho	C	I	Au	Az	F/R	NR	D	P	BnC	LT	RN	CT	Com.
E02	Singh et al. [?]	✓	–	–	✓	–	–	–	–	●	–	–	–	–
E11	Calabretta et al. [?]	✓	–	✓	✓	–	–	–	–	–	–	–	–	–
E13	Dinculeană e Cheng [?]	✓	✓	–	–	–	–	–	–	✓	–	–	–	–
E15	Malina et al. [?]	●	✓	✓	–	–	–	–	✓	–	–	–	–	–
E16	Sadio et al. [?]	✓	✓	–	–	–	–	–	–	✓	–	–	–	–
E19	Segarra et al. [?]	✓	–	✓	–	–	–	–	–	●	–	–	–	–
E20	Dahlmanns et al. [?]	✓	✓	✓	–	–	–	–	–	✓	–	–	–	–
E26	Javadi et al. [?]	✓	✓	✓	–	–	–	–	–	–	–	–	–	–
—	**Proposta**	✓	✓	✓	✓	✓	✓	●	✗	✓	✓	✓	✓	✓

7 Discussão

7.1 Lacunas do estado da arte

A comparação das Secções **??** e **??** evidencia cinco lacunas.

L1. A autenticidade raramente é acompanhada de frescura. Nenhum dos mecanismos analisados reporta proteção contra repetição ou frescura como propriedade garantida. No MQTT, onde os duplicados legítimos do QoS 1 coexistem com repetições maliciosas, a ausência destes mecanismos permite reinjetar mensagens autênticas indefinidamente.

L2. A mensagem não é ligada ao seu contexto. A ligação criptográfica ao tópico, a proteção do modo contra a redução do nível de proteção e a restrição dos tópicos em que cada chave pode publicar não aparecem nos estudos analisados como mecanismos explícitos, apesar de corresponderem a ameaças concretas (mudança de tópico, *downgrade*, dispositivo comprometido).

L3. O *broker* continua, em regra, a ser de confiança. Só seis dos 22 mecanismos dispensam, total ou parcialmente, a confiança no *broker*; a maioria das soluções de autenticação e autorização reforça o *broker* em vez de o tornar irrelevante para a segurança do conteúdo.

L4. O não repúdio está ausente. As soluções baseiam-se em segredos partilhados (palavras-passe, chaves simétricas, ABE), o que não impede quem detém o segredo — incluindo o recetor — de forjar mensagens em nome do remetente.

L5. Custo e benefício não são medidos em conjunto. As avaliações medem o custo do mecanismo, mas raramente o relacionam, no mesmo ensaio, com os ataques que o mecanismo impede; e os mecanismos não são comparáveis entre si por usarem plataformas, cargas e métricas diferentes.

A arquitetura proposta responde diretamente a L1, L2, L3 e L4, e o seu desenho em camadas comutáveis foi pensado para que a segunda parte do projeto responda a L5.

7.2 Ameaças à validade

Seguindo [**?**], identificam-se as principais ameaças à validade desta revisão e as medidas de mitigação adotadas (Tabela **??**).

Table 17. Ameaças à validade da revisão e mitigação.

Tipo	Ameaça	Mitigação
Construção	A *string* pode não captar estudos que usem outra terminologia	Grupos de sinónimos; refinamento após a leitura das revisões; inclusão de MQTT-SN e de termos de deteção
Seleção	Enviesamento na aplicação dos critérios	Dois revisores independentes; kappa de Cohen (Eq. **??**); resolução das divergências por discussão
Extração	Subjetividade na classificação das propriedades; um estudo pode garantir uma propriedade sem a descrever	Formulário fixo; símbolo **?**não reportado**?** distinto de **?**ausente por desenho**?**; confirmação na leitura integral
Externa	Bases de dados e língua limitam a cobertura; enviesamento de publicação	Cinco bases de dados; inglês e português; estudos de revista, conferência e *workshop*
Conclusão	Os números por propriedade dependem da granularidade das categorias	Taxonomia e critérios publicados; dados de extração no Anexo **??**

A ameaça mais relevante é a da extração: as conclusões L1, L2 e L4 assentam em propriedades *não reportadas*, o que não equivale a propriedades *ausentes*. Por isso, a Tabela **??** distingue explicitamente os dois casos e a discussão fala em propriedades **?**não reportadas**?**.

8 Conclusões e trabalho futuro

8.1 Conclusões

Este trabalho apresentou uma revisão sistemática da literatura sobre mecanismos de segurança para comunicações IoT baseadas em MQTT, conduzida segundo um protocolo explícito — perguntas de investigação, PICOC, *strings* de pesquisa por base de dados, critérios de inclusão, exclusão e qualidade, leitura em três passagens e formulário de extração — e relatada com o diagrama PRISMA. Foram analisados 26 estudos primários (2014–2026) e 5 revisões relacionadas.

As principais conclusões são as seguintes:

- O MQTT delega a segurança na implementação, e o TLS, por terminar no *broker*, não protege as mensagens de um *broker* comprometido nem de clientes com acesso legítimo, como mostram os estudos de análise de ameaças.
- A literatura organiza-se em oito categorias. A proteção leve fim-a-fim da mensagem é a mais numerosa, e a confidencialidade, a autenticação e a autorização são as propriedades mais tratadas.
- A frescura e a anti-repetição, a ligação da mensagem ao tópico, a política contra a redução do nível de proteção, a restrição chave–tópico e o não repúdio são pouco ou nada reportados, e a maioria das soluções continua a confiar no *broker*.

- As avaliações medem o custo dos mecanismos, mas raramente o relacionam com os ataques efetivamente impedidos.

Com base nestas lacunas, propôs-se uma arquitetura de segurança em camadas independentes e comutáveis, que combina defesa no transporte, um envelope fim-a-fim formalmente especificado (AES-256-GCM, GMAC ou Ed25519, com o tópico e o cabeçalho nos dados associados, frescura, janela anti-repetição, política de modos e restrição chave–tópico) e limitação de tráfego antes de qualquer operação criptográfica. A proposta não pretende substituir trabalhos com objetivos distintos, como o anonimato ou a proteção do *broker* por TEE, mas combinar numa só camada propriedades que a literatura trata em separado.

8.2 Trabalho futuro

- **Avaliação experimental (segunda parte do projeto)**: medir, para cada combinação de camadas, o custo (latência, processamento, octetos) e o benefício (ataques impedidos) sobre um *broker* real, respondendo à lacuna L5.
- **Verificação formal** das propriedades do envelope, à semelhança de [**?**].
- **Acordo de chaves por dispositivo** (por exemplo, ECDH autenticado), eliminando chaves pré-partilhadas, e persistência do estado anti-repetição.
- **Cifras para nós sem AES em *hardware***, como o ChaCha20-Poly1305 [**?**, **?**], e cifras resistentes à reutilização de *nonces* para chaves de longa duração.
- **Integração com deteção de intrusões** [**?**, **?**], usando as rejeições de cada camada como sinal.
- **Atualização periódica da revisão**, reaplicando o protocolo da Secção **??**.

A *Strings* de pesquisa por base de dados

Todas as pesquisas foram restringidas a publicações de 2014 a 2026. Os grupos G1 a G3 são os da Tabela **??**; nas *strings* secundárias acrescenta-se, com `AND`, o grupo G4.

IEEE Xplore (*Command Search*, campo *All Metadata*)

```
("All Metadata":"MQTT" OR "All Metadata":"MQTT-SN" OR "All Metadata":"MQ Telemetry Transport" OR
"All Metadata":"Message Queuing Telemetry Transport" OR "All Metadata":"Message Queue Telemetry
Transport") AND ("All Metadata":security OR "All Metadata":secure OR "All
Metadata":authentication OR "All Metadata":authorization OR "All Metadata":"access control" OR
"All Metadata":encryption OR "All Metadata":confidentiality OR "All Metadata":integrity OR "All
Metadata":privacy OR "All Metadata":attack* OR "All Metadata":vulnerabilit* OR "All
Metadata":intrusion) AND ("All Metadata":"Internet of Things" OR "All Metadata":IoT OR "All
Metadata":IIoT OR "All Metadata":"publish/subscribe" OR "All Metadata":"publish-subscribe" OR
"All Metadata":"machine-to-machine" OR "All Metadata":M2M)
Filtro: Year 2014-2026; Conferences, Journals.
```

Scopus

```
TITLE-ABS-KEY ( ( "MQTT" OR "MQTT-SN" OR "MQ Telemetry Transport" OR "Message Queuing Telemetry
Transport" OR "Message Queue Telemetry Transport" ) AND ( "security" OR "secure" OR
"authentication" OR "authorization" OR "access control" OR "encryption" OR "confidentiality" OR
"integrity" OR "privacy" OR attack* OR vulnerabilit* OR "intrusion" ) AND ( "Internet of Things"
OR "IoT" OR "IIoT" OR "publish/subscribe" OR "publish-subscribe" OR "machine-to-machine" OR
"M2M" ) ) AND PUBYEAR > 2013 AND PUBYEAR < 2027 AND ( LIMIT-TO ( DOCTYPE , "ar" ) OR LIMIT-TO (
DOCTYPE , "cp" ) ) AND ( LIMIT-TO ( LANGUAGE , "English" ) OR LIMIT-TO ( LANGUAGE , "Portuguese"
) )
```

ACM Digital Library (pesquisa avançada, campos *Title*, *Abstract*, *Keywords*)

```
[[Title: "mqtt"] OR [Abstract: "mqtt"] OR [Keywords: "mqtt"] OR [Abstract: "message queuing
telemetry transport"] OR [Abstract: "mq telemetry transport"]] AND [[Abstract: security] OR
[Abstract: secure] OR [Abstract: authentication] OR [Abstract: authorization] OR [Abstract:
"access control"] OR [Abstract: encryption] OR [Abstract: confidentiality] OR [Abstract:
integrity] OR [Abstract: privacy] OR [Abstract: attack*] OR [Abstract: vulnerabilit*] OR
[Abstract: intrusion]] AND [[Abstract: "internet of things"] OR [Abstract: iot] OR [Abstract:
iiot] OR [Abstract: "publish/subscribe"] OR [Abstract: "publish-subscribe"] OR [Abstract:
"machine-to-machine"] OR [Abstract: m2m]]
Filtro: Publication Date 2014-2026.
```

Web of Science (Core Collection, campo *Topic*)

```
TS=( ("MQTT" OR "MQTT-SN" OR "MQ Telemetry Transport" OR "Message Queuing Telemetry Transport"
OR "Message Queue Telemetry Transport") AND (security OR secure OR authentication OR
authorization OR "access control" OR encryption OR confidentiality OR integrity OR privacy OR
attack* OR vulnerabilit* OR intrusion) AND ("Internet of Things" OR IoT OR IIoT OR
"publish/subscribe" OR "publish-subscribe" OR "machine-to-machine" OR M2M) )
Filtro: PY=(2014-2026); Document Types: Article, Proceedings Paper.
```

ScienceDirect (campo *Title, abstract or author-specified keywords*)

O ScienceDirect não suporta o carácter universal * e limita o número de operadores booleanos por campo; a *string* foi, por isso, dividida em duas consultas cujos resultados foram unidos:

```
(1) ("MQTT" OR "Message Queuing Telemetry Transport") AND (security OR authentication OR
authorization OR encryption) AND ("Internet of Things" OR IoT)

(2) ("MQTT" OR "Message Queuing Telemetry Transport") AND (attack OR attacks OR vulnerability OR
intrusion OR privacy) AND ("Internet of Things" OR IoT)
Filtro: Years 2014-2026; Article types: Research articles.
```

String secundária (revisões), em todas as bases

```
<string principal> AND ("systematic literature" OR "systematic review" OR "literature review" OR
"survey")
```

B Extração de dados por estudo

Table 18. Resumo da extração de dados dos estudos incluídos.

ID	Estudo	Cat.	Contributo principal	Avaliação reportada
E01	Neisse et al. [?]	C3	Integração do SecKit (segurança baseada em modelos) com o MQTT para aplicar regras de política sobre os fluxos de dados	Caso de estudo; viabilidade e desempenho
E02	Singh et al. [?]	C4	SMQTT e SMQTT-SN: KP/CP-ABE sobre ECC leve	Não reportada no resumo
E03	Niruntasukrat et al. [?]	C3	Autorização baseada em OAuth 1.0a adaptada a nós restritos sem interface de utilizador	Plataforma IoT real; atraso de autorização e *overhead*
E04	Shin et al. [?]	C2	Enquadramento de segurança baseado em AugPAKE	Não reportada no resumo
E05	Rizzardi et al. [?]	C3	AUPS: gestão de chaves e aplicação de políticas sobre o MQTT; código aberto (Apache 2.0)	Protótipo de código aberto
E06	Mektoubi et al. [?]	C5	Proteção da comunicação MQTT com criptografia assimétrica; comparação RSA vs. ECC	Não reportada no resumo
E07	Andy et al. [?]	C1	Cenários de ataque ao MQTT sem cifra; razões para a falta de segurança nas implementações	Demonstração de ataques
E08	Firdous et al. [?]	C1	Modelo de ameaças do MQTT; avaliação de negação de serviço contra *brokers*	Avaliação experimental de DoS
E09	Bisne e Parmar [?]	C4	Combinação de ABE com AES de *S-box* dinâmica	Não reportada no resumo
E10	Harsha et al. [?]	C3	Vulnerabilidades identificadas com a API do Shodan; autenticação e ACL como contramedidas	*Broker* em Raspberry Pi; clientes em Python

ID	Estudo	Cat.	Contributo principal	Avaliação reportada
E11	Calabretta et al. [?]	C3	MQTT-Auth: AugPAKE para confidencialidade e dois *tokens* (autenticação e autorização por tópico); hierarquias de tópicos	Comparação com soluções da literatura
E12	Hernández Ramos et al. [?]	C1	Enquadramento de *fuzzing* baseado em modelos para o MQTT	Resultados experimentais iniciais
E13	Dinculeană e Cheng [?]	C5	Mapeamento *Value-to-HMAC*: confidencialidade e integridade com um só mecanismo	Desempenho face a cifra simétrica
E14	Lohachab e Karambir [?]	C2	Autenticação e autorização leves entre dispositivos com ECC e MQTT	Implementação; comparação de segurança e desempenho
E15	Malina et al. [?]	C5	Três níveis de segurança: integridade, privacidade de fontes e recetores, segurança de longo prazo com autenticação mútua	Não reportada no resumo
E16	Sadio et al. [?]	C5	AEAD ChaCha20-Poly1305 fim-a-fim para MQTT e MQTT-SN	Arduino UNO; memória e tempo de execução
E17	Vaccari et al. [?]	C1	SlowITe: DoS de baixa taxa que explora a configuração do servidor pelo cliente	Serviços MQTT reais, com e sem cifra
E18	Vaccari et al. [?]	C7	MQTTset: conjunto de dados de tráfego MQTT legítimo e de ataques	Sistema de deteção por ML
E19	Segarra et al. [?]	C6	MQT-TZ: *broker* em ARM TrustZone; TLS mútuo e cifra em duas camadas	Micro e macro *benchmarks*; cargas de uma aplicação médica
E20	Dahlmanns et al. [?]	C5	ENTRUST: segurança fim-a-fim baseada em servidor de chaves, sem alterar o protocolo	Implementação sobre MQTT
E21	Spielvogel et al. [?]	C6	O *broker* só reencaminha por ligações com o nível de segurança exigido	Protótipo; medições de *overhead*
E22	Prantl et al. [?]	C6	Impacto do TLS no MQTT: débito, estabelecimento de ligação, energia	Microcontrolador comercial; todos os níveis de QoS
E23	Van Glabbeek et al. [?]	C5	Segurança muitos-para-muitos leve integrada no MQTT	$-80\,\%$ *overhead* de comunicação e $-40\,\%$ computacional face ao MQTTS
E24	Buccafurri et al. [?]	C8	MQTT-A: anonimato de *publishers* e subscritores via *bridges*	*Brokers* em nuvem em vários países; latência e *goodput*
E25	Alotaibi et al. [?]	C7	Deteção distribuída de anomalias com H2O (melhor: XGBoost)	MSE, RMSE, erro por classe, *log loss*
E26	Javadi et al. [?]	C2	CMAP: autenticação mútua sem certificados sobre ECC	Verificação formal; Raspberry Pi com Mosquitto; NS-3